

«Московское долголетие» — варианты пути реализации

Все суммы — рубли, ориентир (финал — в договоре). Архитектура уже заложена (два изолированных контура с разрезом по персональным данным), варианты различаются **только режимом защиты и инфраструктурой**, не переписыванием системы.

1. Почему путей несколько

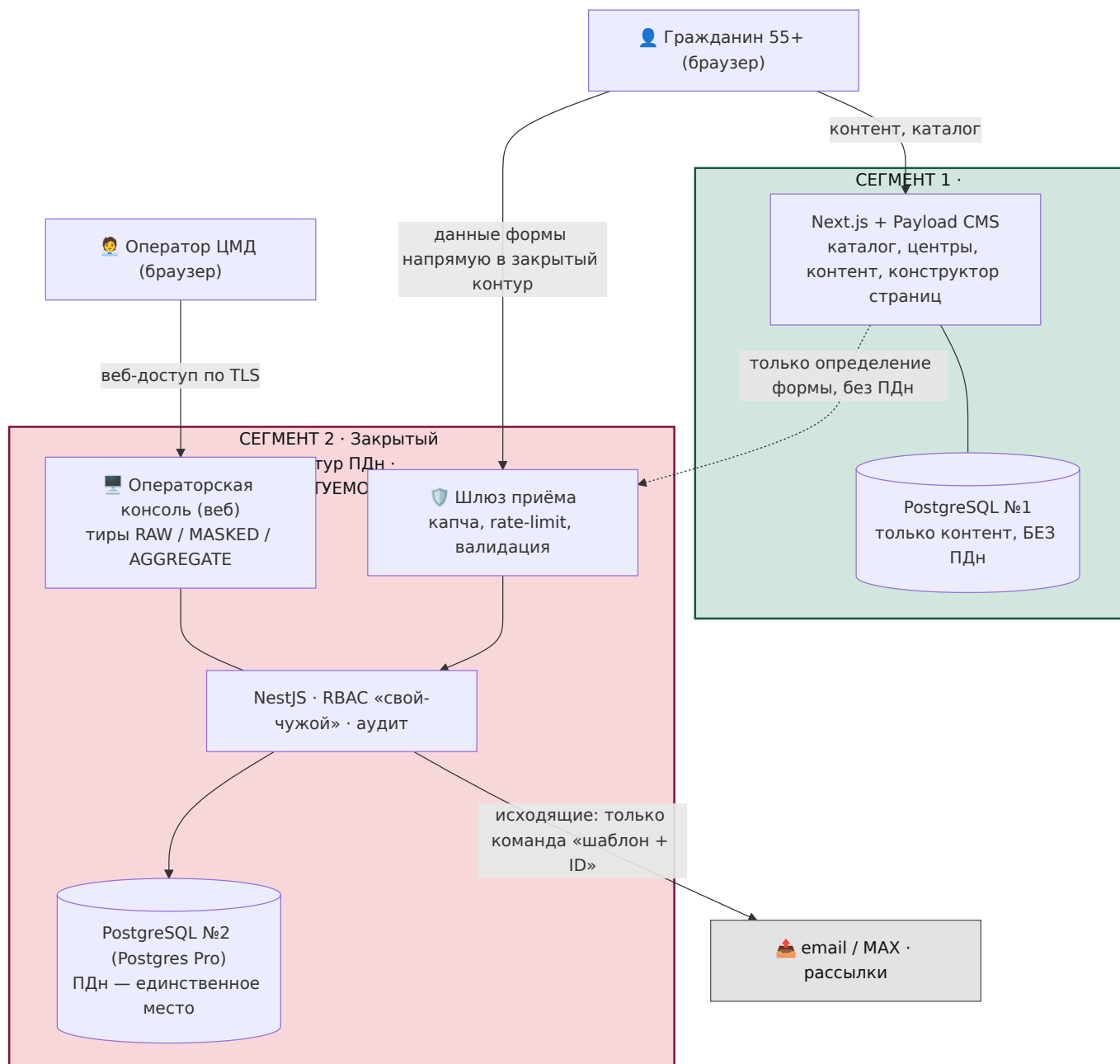
Мы задали вопросы — вы дали часть ответов. Из них однозначно следует несколько решений, а остальное создаёт **развилку**: в зависимости от 3 ваших ответов проект идёт по одному из трёх путей, и они по-разному ложатся в деньги и сроки.

Ваш ответ	Что из него следует
Интеграции с КИС МД нет (только ссылка на личное дело + посещаемость)	Убираются ГОСТ-VPN, криптошлюз, аттестация узла сопряжения. Посещаемость — ручной ввод/импорт
mos.ru/ЕСИА не дадут	Нужна своя форма записи + решение по авторизации гражданина
Своей аттестованной площадки у ДТСЗН нет	Закрытый контур ПДн — в аттестованном облаке РФ
Приказ ФСТЭК №117 применим	Режим защиты зависит от статуса (ГИС/ИСПДн) и класса (К1/К2/К3)
Стиль — текущий брендбук	Сохраняем фирстиль; обязательная доступность 55+ — приоритет (ГОСТ Р 52872)

Три ещё не закрытых ответа и создают три пути: (1) статус системы — ГИС или ИСПДн госучреждения; (2) есть ли у вас защищённый сегмент рабочих мест операторов; (3) нужен аттестат или достаточно «оценки эффективности».

2. Базовая архитектура (одна для всех путей)

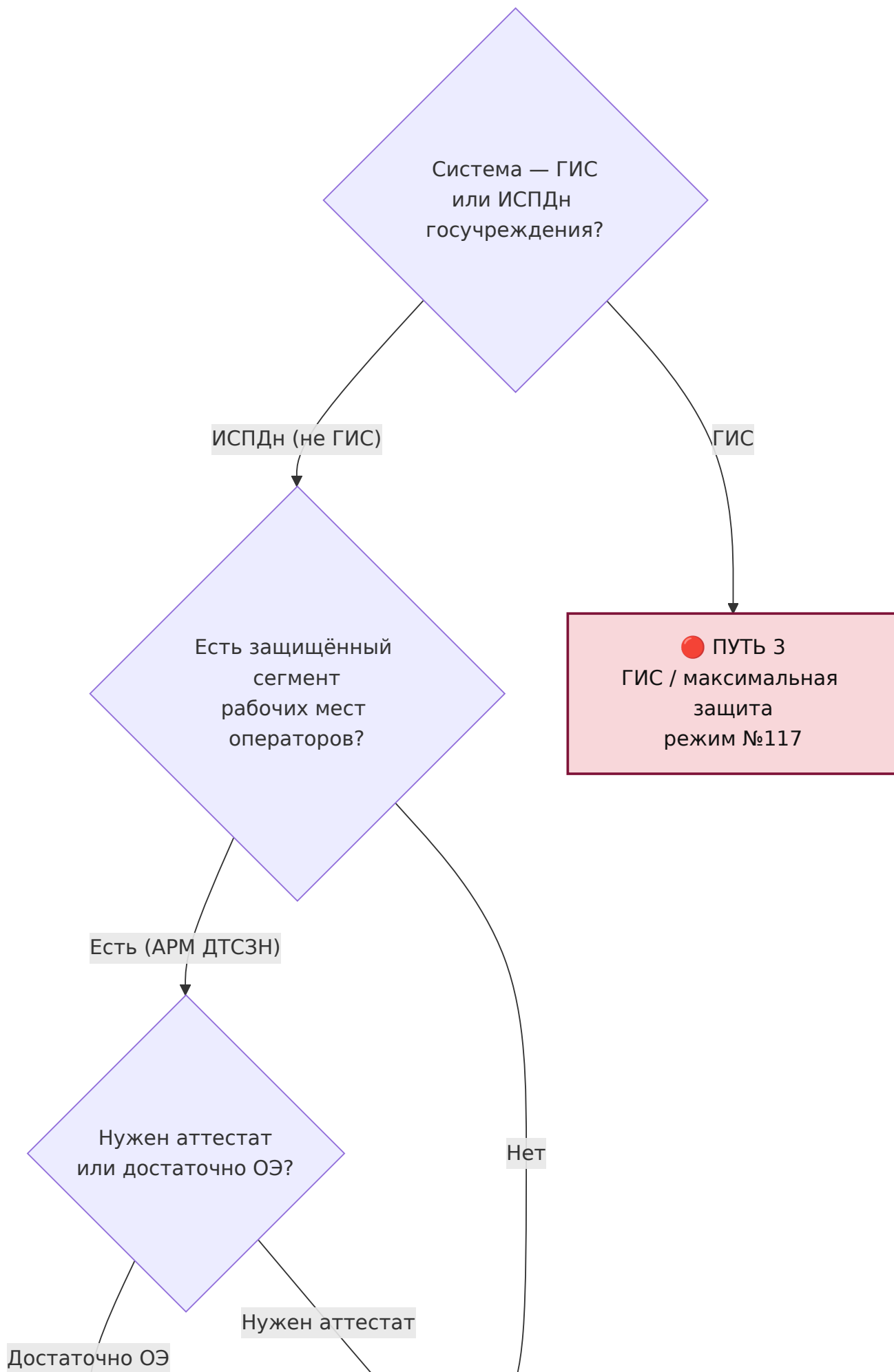
Система разрезана на два контура по линии персональных данных. Публичный портал — **вне периметра** аттестации; персданные живут только в закрытом контуре. Это не меняется ни в одном из путей — меняется только режим защиты закрытого контура.

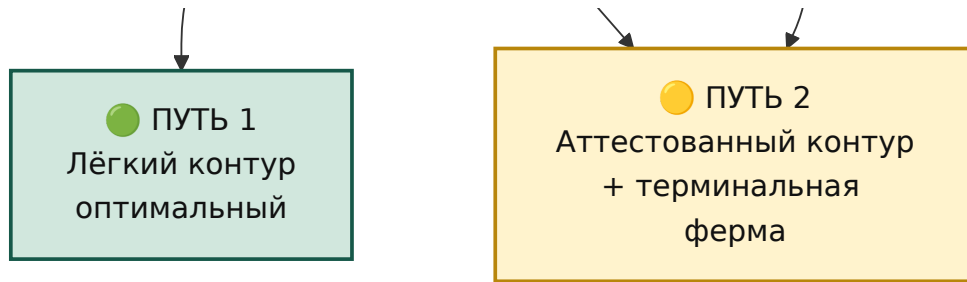


Что это даёт во всех путях:

- Публичный портал запускается **за 3–6 недель**, не дожидаясь аттестации (он вне периметра).
- ПДн физически не проходят публичный сайт: браузер отправляет данные формы напрямую в закрытый контур, минуя публичную часть.
- Операторы работают **через браузер** (модель облачной CRM, как amoCRM/Битрикс24) — аттестуется серверный контур, рабочие места не хранят и не обрабатывают ПДн локально.
- Показ ПДн маскируется **на сервере** по ролям (RAW/MASKED/AGGREGATE).

3. Развилка → три пути





4. Три пути подробно

● Путь 1 — «Лёгкий контур» (оптимальный, к которому стремимся)

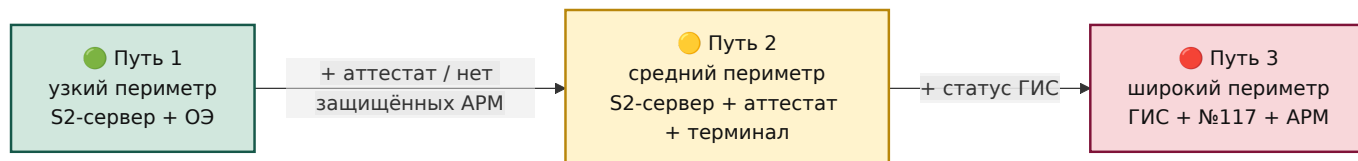
- **Статус:** ИСПДн госучреждения (не ГИС) → границу и состав защиты определяет оператор.
- **Compliance:** «Оценка эффективности» (ОЭ) вместо аттестата — легально для ИСПДн, повтор раз в 3 года, не ежегодно.
- **Инфраструктура:** аттестованное облако РФ, где сертифицированные средства защиты входят в подписку провайдера (капзатраты на СЗИ = 0).
- **Рабочие места:** операторы заходят браузером на **уже защищённые АРМ ДТСЗН** (домен/антивирус под другие ваши ИСПДн) → средства защиты на каждое место **не покупаются**.
- **Модель ПДн:** D — храним + маскируем показ + click-to-call (номер оператору не виден).
- **Периметр:** самый узкий. **Риски:** требует подтверждения «не-ГИС» + наличия защищённого сегмента АРМ + согласия лицензиата на узкую границу.

● Путь 2 — «Аттестованный контур» (средняя, реалистичный базовый)

- **Статус:** ИСПДн, но регламент требует именно **аттестат** (не ОЭ).
- **Compliance:** полноценная аттестация **узкого серверного контура** (только S2), портал вне периметра.
- **Инфраструктура:** аттестованное облако РФ.
- **Рабочие места:** если готового защищённого сегмента АРМ у ДТСЗН нет — разворачиваем **терминальную ферму (2–3 сервера)**, операторы — через тонкий доступ; средства защиты не множатся на каждое место.
- **Модель ПДн:** D.
- **Периметр:** средний. **Риски:** срок аттестации 2–4 мес (идёт параллельно разработке).

● Путь 3 — «ГИС / максимальная защита» (максимальная, потолок)

- **Статус:** система признана **ГИС** → включается **полный режим Приказа №117**: непрерывный контроль, метрики защищённости (Кзи) раз в 6 мес с отчётом во ФСТЭК, управление уязвимостями.
- **Compliance:** полная аттестация, возможно повышенный класс (K2).
- **Рабочие места:** средства защиты на каждое место (per-seat) либо расширенная терминальная инфраструктура.
- **Модель ПДн:** опционально С — токен-сейф (сырьё в крошечном сейфе, AI/аналитика на токенах вне периметра); +переделка.
- **Периметр:** широкий. **Риски:** максимальные разовые и **постоянные** затраты; самый долгий критпуть.



5. Сводная таблица: деньги + время (с детальной разбивкой)

Разработка системы — **одинаковая** во всех путях (мы достраиваем уже работающую систему, ≈60–65% готово): **3,5 млн база / 4,2 млн с AI-слоем**. Различаются только аттестация, оснащение рабочих мест и эксплуатация. Цифры ниже — итог независимого разбора (две оценки + сведение), суммы в Р.

5.1. Что входит в аттестацию (разовое, без стоимости разработки)

Статья	Что входит (простыми словами)	Мин	Макс	В каких путях
1. Обследование + классификация	Инвентаризация, состав ПДн, фиксация уровня защиты УЗ-3, акт классификации	40 000	90 000	1 • 2 • 3
2. Модель угроз	Документ «модель угроз и нарушителя»: какие угрозы актуальны, почему спецкатегории исключены	60 000	140 000	1 • 2 • 3
3. Пакет документов ПДн/ИБ (ОРД)	Политики, приказы, регламенты, инструкции, журналы, согласия — «бумажный периметр» 152-ФЗ	120 000	300 000	1 • 2 • 3
4. Работы лицензиата ФСТЭК	Путь 1 — оценка эффективности (ОЭ); Путь 2/3 — аттестационные испытания + аттестат	150 000	1 200 000	1 (ОЭ) / 2 (аттестат) / 3 (полный)
5. Анализ уязвимостей	Сканирование контура, проверка настроек защиты, устранение находок	60 000	200 000	1 • 2 • 3
6. Пентест (опционально)	Тест на проникновение. Для УЗ-3 не обязателен — только как добровольная мера	0	350 000	2 (опц.) • 3
7. Средства защиты серверного контура	МЭ, антивирус, контроль доступа в облаке. В Пути 1 — входят в подписку облака (= 0 здесь)	0	500 000	2 • 3 (в Пути 1 = 0)

8. Оснащение рабочих мест операторов	Путь 1 — доступ с уже защищённых мест ДТСЗН (0); Путь 2 — терминальная ферма 2–3 сервера; Путь 3 — расширенный per-seat	0	900 000	1 = 0 / 2 / 3
9. Юр-блок	Уведомление Роскомнадзора, формы согласий, назначение ответственного за ПДн, политика на сайте	30 000	120 000	1 • 2 • 3
ИТОГО разовое (аттестация)				П1: 0,23–0,53 млн • П2: 0,8–1,8 млн • П3: 1,75–3,45 млн

5.2. Что входит в эксплуатацию (в год, без стоимости разработки)

Статья	Что входит	Мин	Макс	В каких путях
1. Облако — контур ПДн	Аренда аттестованного облака РФ со средствами защиты в подписке + ресурсы CRM	300 000	700 000	1 • 2 • 3
2. Публичный хостинг + CDN	Хостинг портала (вне периметра ПДн), CDN, анти-DDoS	60 000	180 000	1 • 2 • 3
3. Поддержка / SLA	Сопровождение инфраструктуры и защиты, реагирование на инциденты, обновления	150 000	500 000	1 • 2 • 3
4. Резервное копирование	Бэкап контура ПДн, хранение копий, проверка восстановления	40 000	150 000	1 • 2 • 3
5. Процессный режим №117	Управление уязвимостями + периодический контроль защищённости (для УЗ-3 — в усечённом объёме)	80 000	300 000	1 • 2 • 3
6. Повторная оценка / переаттестация (в год)	Путь 1 — переоценка эффективности; Путь 2/3 — поддержание аттестата (разнесено по годам)	50 000	250 000	1 • 2 • 3
7. Ответственный за ПДн	Доля ставки сотрудника: журналы, взаимодействие с Роскомнадзором	50 000	200 000	1 • 2 • 3
ИТОГО эксплуатация / год				П1: 0,7–1,3 млн • П2: 0,97–1,9 млн • П3: 1,28–2,4 млн

5.3. Итог по трём путям

«Под ключ (1-й год)» = разработка + разовое (аттестация) + первый год эксплуатации. Со 2-го года остаётся только строка «эксплуатация/год».

Путь	Разовое (аттестация)	Эксплуатация / год	Под ключ, 1- й год (база 3,5)	До портала	До аттестата/ ОЭ
 Путь 1 (оптимальный)	0,23–0,53 млн	0,70–1,30 млн	4,43–5,33 млн	3–6 нед	~2 мес (ОЭ)
 Путь 2 — средняя линия	0,80–1,80 млн	0,97–1,90 млн	5,27–7,20 млн	3–6 нед	2–4 мес
 Путь 3 — максимальная	1,75–3,45 млн	1,28–2,40 млн	6,53–9,35 млн	3–6 нед	4–9 мес

С AI-слоем (4,2 вместо 3,5) — прибавьте +0,7 млн к строке «под ключ». **Ожидаемый коридор под ключ (взвешенно по вероятностям ниже): ≈ 5,2–6,9 млн (база) / 5,9–7,6 млн (с AI).**

5.4. Вероятность каждого пути (по итогам разбора)

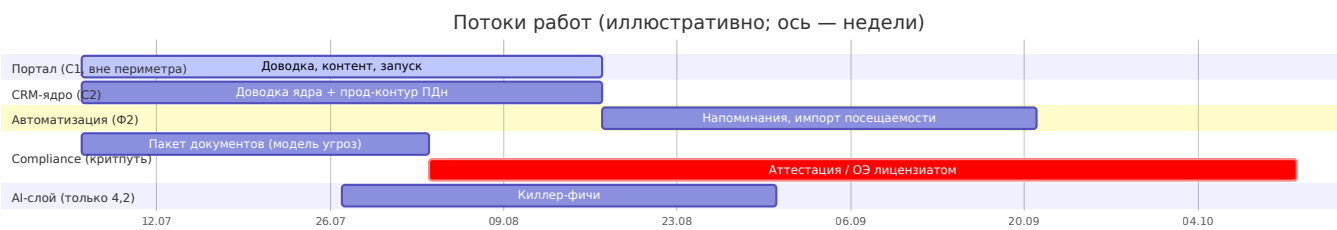
Путь	Вероятность	Почему
 Путь 1	35 %	Нормативно достаточен (не-ГИС + ОЭ), но нужно, чтобы у ДТСЗН уже были защищённые рабочие места и облако со средствами защиты в подписке
 Путь 2	48 %	Наиболее вероятный: служба ИБ обычно требует формальный аттестат узкого контура, а готовых защищённых мест может не быть → терминальная ферма
 Путь 3	17 %	Только при волевом решении на полный аттестат или повышении класса до К2; нормативно избыточен

5.5. Две переменные, которые двигают цену (закрывает заказчик)

- А. Аттестат или оценка эффективности?** При статусе «не-ГИС» допустимы оба; выбор за руководителем. Оценка эффективности удерживает Путь 1; формальный аттестат сдвигает в Путь 2/3 → **+0,3...+2,9 млн к разовым**. Самый дорогой рычаг.
- Б. Число рабочих мест операторов и есть ли защищённый сегмент?** Есть → оснащение = 0 (Путь 1). Нет → терминальная ферма → **+0,3...+0,9 млн к разовым** + выше эксплуатация.

Пока обе переменные не закрыты, для бюджета разумно планировать **Путь 2** (вероятность 48 %), а Путь 1 держать как целевую экономию при подтверждённой готовности рабочих мест и согласии на оценку эффективности.

6. Сроки и параллельность (диаграмма Гантта)



Вывод: публичный портал — у пользователей через ~1–1,5 месяца. Закрытый контур «под ключ» — по мере аттестации, которая идёт **параллельно** разработке, а не после неё.

7. Что идёт параллельно, а что сливаем в один этап

Параллельно (не блокируют друг друга):

- Публичный портал ⊥ CRM-ядро ⊥ аттестация (лицензиат) ⊥ наполнение контентом.
- Портал запускается, **не дожидаясь** аттестата (S1 вне периметра).

Сливаем в один этап (экономия времени):

- Прод-контур ПДн + развёртывание S2 + подготовка пакета документов (модель угроз, акт классификации) — готовятся **во время** разработки ядра, а не отдельной фазой после.

Строго последовательно (критпуть — нельзя слить):

- Ваши ответы (статус/класс/APM) → акт классификации → согласование модели угроз → [закупка СЗИ, если нужна] → аттестация/ОЭ → аттестат.
- Этот путь **длиннее разработки**, поэтому запускаем его в первую же неделю. Чтобы он не блокировал сдачу MVP — аттестуем ядро **двумя волнами**: сначала ядро без живых внешних интеграций, потом отдельной дооценкой подключаем интеграции.

8. Главные риски и как мы их купируем

#	Риск	Как купируем
1	Систему классифицируют как ГИС → режим №117, дороже ежегодно	Зафиксировать статус письменно до договора; минимизация ПДн держит класс низким; режим №117 — отдельной строкой эксплуатации, не «сюрпризом»
2	На приёмке «всплывает» периметр рабочих мест	Модель угроз + серверный запрет выгрузки/печати + узкую границу согласуем с лицензиатом заранее ; вопрос про защищённый сегмент APM закрываем сейчас

3	Медданные → подъём на УЗ-1 (кратно дороже)	Храним только «допуск да/нет» + нейтральные коды; ссылку на личное дело у себя не раскрываем
4	Аттестация длиннее разработки → срыв сроков	Аттестация двумя волнами; портал вне периметра; пакет документов — с первой недели
5	Ручной ввод посещаемости / у МАХ нет серверного API	Удобный импорт Excel/CSV для операторов; уведомления — email-first за фиче-флагом, МАХ — ручной канал/позже; не блокирует запуск
6	Конфликт «текущий стиль» ↔ доступность 55+	Брендбук — источник цвета/лого; обязательная доступность (контраст/кегель/размер кнопок, ГОСТ Р 52872) имеет приоритет — фиксируем письменно

9. Дополнительные вопросы (чтобы закрыть рамку проекта)

- Нагрузка и сезонность.** Сколько заявок в пик (сентябрь) и сколько операторов работают одновременно? Нужно для размера контура и нагрузочного теста.
- Эксплуатация после сдачи.** Какой SLA (доступность, время реакции)? Кто эксплуатирует систему после первых 12 месяцев — мы по договору сопровождения или ДТСЗН забирает себе?
- Права на результат.** Кому принадлежит код/система после сдачи? Нужна ли регистрация в реестре отечественного ПО? Условия передачи исходников.
- Ответственный по защите информации.** Кто со стороны ДТСЗН согласует модель угроз и акт классификации и в какие сроки? Это критический путь аттестации — нужен ответственный и ориентир по времени.
- Юр-оформление ПДн.** Уведомление в Роскомнадзор и отдельные согласия участников (по требованиям с 01.09.2025) — мы готовим шаблоны или это делают ваши юристы?
- Приёмка и хранение.** По какому документу проходит госприёмка и нужен ли пилот на нескольких центрах перед раскаткой на все 134? Какие сроки хранения и удаления персданных (нужно для модели угроз и резервных копий)?

10. Рекомендация

- Цель — Путь 1** (лёгкий контур): он даёт минимальные разовые и ежегодные затраты при той же системе. Чтобы на него встать, нужно подтвердить три вещи: статус **ИСПДн (не ГИС)**, наличие **защищённого сегмента рабочих мест**, достаточность **ОЭ**.
- Реалистичный базовый — Путь 2:** если потребуется аттестат и/или у вас нет готового сегмента АРМ. Это и есть **средняя линия** бюджета.
- Путь 3 (ГИС) — потолок**, который мы показываем честно: если систему отнесут к ГИС, включается постоянный режим №117 и максимальные затраты. От него уходим, зафиксировав статус не-ГИС там, где это законно.

Во всех трёх путях разработка одинакова, а архитектура B-lite уже построена. Разница — исключительно в режиме защиты закрытого контура, и ею управляют ваши три ответа. Это и предлагаем согласовать.